SICUREZZA INFORMATICA



Proteggere dati, persone e servizi nel mondo digitale

Prof. Antonio Natale

Cosa impareremo

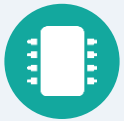
- Che cos'è la sicurezza informatica e a cosa serve
- Quando un sistema è sicuro: riservatezza, integrità, disponibilità
- Password, firewall e backup
- Riconoscere malware e phishing
- Proteggere operazioni e dati online

Perché ci riguarda

Dal tuo smartphone alla cartella clinica di una persona assistita: le regole sono le stesse, cambia l'importanza di ciò che si protegge.



Che cos'è la sicurezza informatica



Tecnologie

Antivirus, firewall, password, crittografia.



Regole

Chi può fare cosa, procedure, backup programmati.



Persone

Comportamenti attenti e formazione: è la difesa più importante.

Insieme delle misure che proteggono computer, reti, programmi e dati da accessi non autorizzati, danni, furti e perdite.

Lo scopo: proteggere



I dati

Non letti, non alterati, non persi. Es. cartella clinica, PAI.



I sistemi

Devono funzionare quando servono. Es. prenotazioni, turni.



Le persone

Evitare truffe e danni, soprattutto ai più fragili.



La legge

Rispettare privacy e GDPR: i dati sanitari sono "particolari".

Quando un sistema è sicuro? La triade CIA



Riservatezza

Confidentiality

Chi può leggere i dati?



Integrità

Integrity

I dati sono corretti e non alterati?



Disponibilità

Availability

Sono accessibili quando servono?

Un sistema è sicuro solo se garantisce tutte e tre le proprietà insieme.

Riservatezza (Confidenzialità)

C

Le informazioni possono essere lette solo da chi è autorizzato.

✓ Esempio corretto

Solo il personale del reparto apre la cartella del paziente.

✗ Violazione

Un visitatore legge una cartella su un PC lasciato acceso e senza password.

Come si garantisce: password, profili di accesso per ruolo, crittografia, blocco schermo.

Integrità (Integrity)

I

I dati sono corretti, completi e non modificati senza autorizzazione.

✓ Esempio corretto

La terapia inserita dal medico è quella che legge l'infermiere.

✗ Violazione

Un virus o un errore cambia il dosaggio di un farmaco in cartella.

Come si garantisce: permessi limitati, registro degli accessi, firma digitale, backup, antivirus.

Disponibilità (Availability)

A

Dati e servizi sono accessibili quando servono alle persone autorizzate.

✓ Esempio corretto

Alle 3 di notte l'infermiere consulta la terapia del paziente.

✗ Violazione

Un ransomware o un black out blocca il sistema del reparto.

Come si garantisce: backup, gruppo di continuità (UPS), aggiornamenti, antivirus.

Le tre proprietà a confronto

	Riservatezza	Integrità	Disponibilità
Domanda	Chi può leggere?	I dati sono giusti?	Funziona quando serve?
Minacce	Accessi non autorizzati, spyware, phishing	Virus, errori, modifiche abusive	Guasti, black out, ransomware
Difese	Password, crittografia, profili	Firma digitale, permessi, backup	Backup, UPS, aggiornamenti

Come si proteggono i dati



Username e password

Username: chi dichiari di essere. Password: dimostra che sei tu.



Biometria

Impronta, iride, volto. Non si dimentica, ma non si può cambiare.



Firewall

Il "portiere" della rete: filtra i dati in entrata e uscita. Hardware o software.



Backup

Copia dei dati per ripristinarli. Regola 3-2-1: 3 copie, 2 supporti, 1 fuori sede.

Il firewall: il portiere della rete



Internet

Dati in arrivo: buoni e sospetti

Firewall

Controlla tutto: passa solo ciò che è permesso

Rete della struttura

Computer, server e cartelle protetti

Blocca gli accessi non autorizzati, ma non sostituisce l'antivirus e l'attenzione dell'utente.

Backup: la regola del 3-2-1



Copia 1: il computer

I dati originali

Copia 2: hard disk esterno

Secondo supporto, diverso dal PC

Copia 3: cloud

Una copia in un luogo diverso

3 copie · 2 supporti diversi · 1 copia fuori sede. Prova ogni tanto un ripristino: un backup mai provato non è affidabile.

Tre modi di fare il backup

Completo

Copia TUTTI i dati, ogni volta. Come fotocopiare tutto il quaderno.

Incrementale

Copia solo ciò che è nuovo dall'ultimo backup, di qualunque tipo. Come fotocopiare solo le pagine scritte dopo l'ultima fotocopia.

Differenziale

Copia ciò che è nuovo dall'ultimo backup COMPLETO. Come fotocopiare tutte le pagine scritte dopo la prima fotocopia completa.

Si parte sempre da un backup completo: poi cambia solo il modo di copiare le novità.

Backup completo (full)

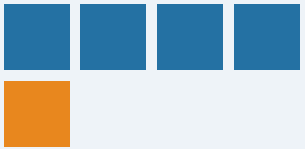
Ogni giorno viene copiato TUTTO, anche ciò che non è cambiato.

Lunedì



Copiati: 4 blocchi

Martedì



Copiati: 5 blocchi

Mercoledì



Copiati: 6 blocchi

Giovedì



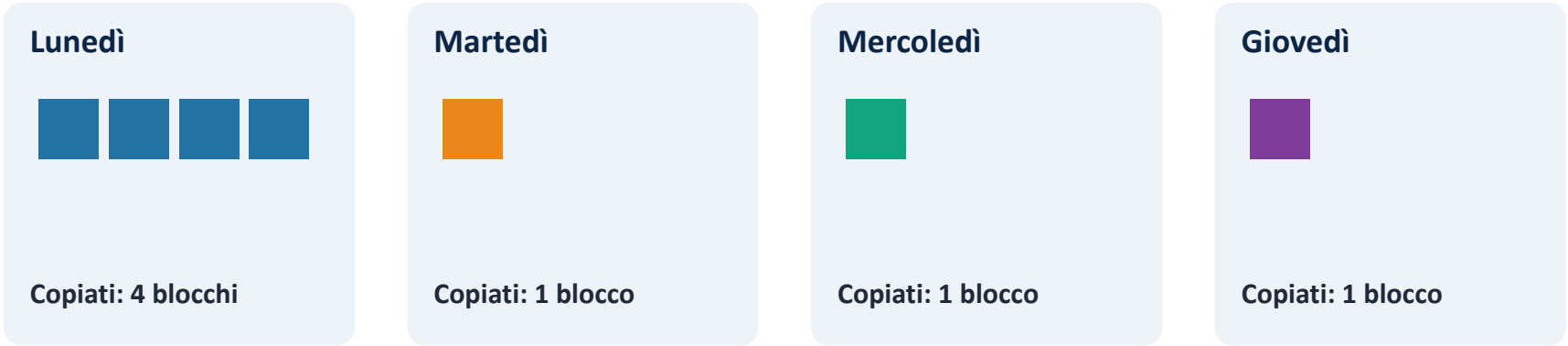
Copiati: 7 blocchi

■ dati di lunedì ■ novità di martedì ■ novità di mercoledì ■ novità di giovedì

✓ Ripristino velocissimo: basta una sola copia.
✗ Occupa molto spazio e richiede molto tempo.

Backup incrementale

Dopo il primo backup completo, ogni giorno si copia solo ciò che è nuovo rispetto al backup del giorno prima.



■ dati di lunedì ■ novità di martedì ■ novità di mercoledì ■ novità di giovedì

✓ Veloce e occupa pochissimo spazio.
✗ Per ripristinare servono TUTTE le copie in ordine: se una si rovina, la catena si spezza.

Backup differenziale

Dopo il primo backup completo, ogni giorno si copia tutto ciò che è cambiato dall'ultimo backup COMPLETO (quello di lunedì).

Lunedì



Copiati: 4 blocchi

Martedì



Copiati: 1 blocco

Mercoledì



Copiati: 2 blocchi

Giovedì

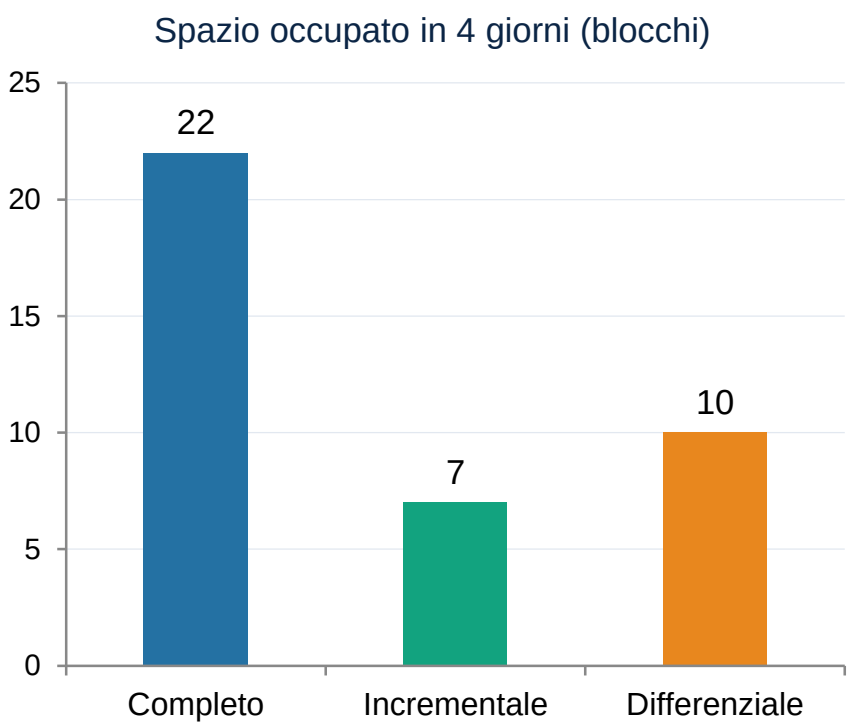


Copiati: 3 blocchi

■ dati di lunedì ■ novità di martedì ■ novità di mercoledì ■ novità di giovedì

✓ Ripristino con sole 2 copie: il completo + l'ultimo differenziale.
✗ Ogni giorno la copia cresce: dopo qualche giorno pesa quasi come un completo.

Confronto: spazio e ripristino



Ripristino di giovedì: quante copie servono?

Completo

1 copia: quella di giovedì.

Incrementale

4 copie: lunedì + martedì + mercoledì + giovedì, in ordine.

Differenziale

2 copie: lunedì (completo) + giovedì.

I tre backup a confronto

	Completo	Incrementale	Differenziale
Cosa copia	Tutti i dati	Le novità dall'ultimo backup (di qualsiasi tipo)	Le novità dall'ultimo backup completo
Spazio	Molto	Poco	Medio, cresce ogni giorno
Tempo del backup	Lungo	Breve	Medio
Ripristino	Veloce e semplice	Lento: serve tutta la catena	Abbastanza veloce: completo + ultimo differenziale

Strategia tipica: un backup completo a settimana (es. domenica) + copie incrementali o differenziali ogni notte, e una copia fuori sede. In una RSA i dati cambiano ogni giorno: senza copie notturne si perderebbe il lavoro di un'intera settimana.

La password efficace

- Niente informazioni personali
- Non detta a nessuno, non scritta su post-it
- Lunga (12+ caratteri) e complessa
- Diversa per ogni servizio
- Cambiata subito se hai dubbi

Debole o forte?

✗ 123456
✗ giulia2010
✓ Ogni-Mattina-Bevo-2-Caffè!

Una frase lunga è facile da ricordare e difficile da indovinare.



Caso simulato: il post-it sul monitor

In una RSA le operatrici scrivono la password del PC su un post-it attaccato al monitor, per fare prima. Un parente in visita la legge e apre la cartella di un altro ospite.



Domande

1. Quale proprietà (R, I, D) è stata violata?
2. Che cosa cambieresti?

Risposte guida

1. Riservatezza (e integrità, se il parente modifica qualcosa).
2. Password personale e segreta, blocco schermo automatico, badge o impronta per accedere in fretta, breve formazione al personale.

Malware: le categorie

Tipo	Cosa fa	Come si diffonde
Virus	Danneggia file e sistema	Quando l'utente passa o apre file infetti
Worm	Si copia da solo	Da solo, via rete LAN o Internet
Trojan horse	Si nasconde in programmi "utili"	Installato dall'utente ignaro; non si replica
Spyware	Spia e invia i dati a estranei	Nascosto in programmi gratuiti
Ransomware	Blocca i file e chiede un riscatto	Allegati e siti infetti

Malware: il virus



Piccolo programma che si attacca a un file e si attiva quando l'utente lo apre. Come un virus biologico, ha bisogno di un "ospite".

Come si diffonde

Chiavette USB, allegati, file scaricati e passati da persona a persona.

Che cosa fa

Rovina o cancella file, rallenta il computer, può impedirne l'avvio.

Esempio e difesa

Un file "Turni.docm" infetto su una chiavetta. Antivirus, scansione delle chiavette, niente file sospetti.

Proprietà colpita: Integrità, Disponibilità

Malware: il worm ("verme")



Programma che si copia da solo da un computer all'altro attraverso la rete, senza bisogno che l'utente faccia qualcosa.

Come si diffonde

Sfrutta i "buchi" dei sistemi non aggiornati, in reti LAN e su Internet.

Che cosa fa

Si replica migliaia di volte: rallenta o blocca reti e server.

Esempio e difesa

In una struttura con 50 PC in rete, uno solo infetto può contagiare tutti. Aggiornamenti, firewall, isolare il PC infetto.

Proprietà colpita: Disponibilità

Malware: il trojan horse



Programma che sembra utile o innocuo (un gioco, un "aggiornamento") ma nasconde una funzione dannosa, come il cavallo di Troia.

Come si diffonde

Lo installa l'utente stesso, ingannato. Non si copia da solo.

Che cosa fa

Cancella dati, ruba password, apre una "porta" ai criminali per controllare il computer.

Esempio e difesa

Un "convertitore PDF gratuito" che intanto invia le tue password. Scarica solo da siti ufficiali, diffida del software piratato.

Proprietà colpita: Riservatezza, Integrità, Disponibilità

Malware: lo spyware



Programma che spia in silenzio ciò che fai e invia le informazioni a estranei.

Come si diffonde

Nascosto in programmi gratuiti, estensioni del browser, app non ufficiali.

Che cosa fa

Registra ciò che scrivi (password), la cronologia, a volte usa microfono e fotocamera.

Esempio e difesa

Un'app "torcia" gratuita che legge i contatti. Controlla i permessi delle app, usa antivirus, installa solo app ufficiali.

Proprietà colpita: Riservatezza

Malware: il ransomware



Programma che blocca o cifra i file e chiede un riscatto (ransom) per restituirli.

Come si diffonde

Allegati di e-mail (phishing), siti infetti, computer non aggiornati.

Che cosa fa

Cartelle inaccessibili e schermata con richiesta di denaro; a volte i dati vengono anche copiati.

Esempio e difesa

Colpisce anche ospedali e RSA. Backup 3-2-1 separati dal PC, aggiornamenti, formazione. Avvisa subito il responsabile.

Proprietà colpita: Disponibilità, Riservatezza

Come proteggersi dai malware

- Antivirus installato e aggiornato
- Aggiorna sistema e programmi
- Non aprire allegati inattesi
- Scarica solo da fonti ufficiali
- Non usare chiavette sconosciute
- Fai i backup

Come arrivano

- Chiavette USB infette
- Download da siti non affidabili
- Allegati di e-mail e messaggi

Quasi sempre è una persona a farli entrare, senza saperlo.



Caso simulato: il ransomware in ospedale

Lunedì mattina, su tutti i computer di una struttura sanitaria compare: "I tuoi file sono cifrati. Paga per riaverli". Non si apre nessuna cartella clinica: il personale torna a carta e penna.



Domande

1. Quali proprietà sono violate?
2. Come può essere entrato il malware?
3. Che cosa avrebbe ridotto il danno?

Risposte guida

1. Disponibilità (e riservatezza se i dati sono stati copiati).
2. Probabilmente una mail con allegato infetto o software non aggiornato.
3. Backup recenti e separati, aggiornamenti, antivirus, personale formato.

Il phishing: la truffa che "pesca"

Messaggio falso

Mail, SMS o telefonata da banca, corriere, ASL.

Urgenza o paura

"Il conto sarà bloccato in 24 ore!"

Clic o dati

La vittima apre il link o dà password e codici.

Furto

Soldi, identità o accesso rubati.

Segnali: mittente strano, fretta, errori, link sospetti, richiesta di password. Nessun ente serio chiede password per mail o SMS.

Caso simulato: l'SMS alla signora Maria

La signora Maria, 82 anni, assistita a domicilio, riceve un SMS: "Il tuo pacco è bloccato. Clicca qui per pagare 1,99 € di spese". Chiede all'operatrice se deve farlo.



Domande

1. È phishing? Quali segnali lo mostrano?
2. Che cosa risponde l'operatrice?
3. E se Maria avesse già inserito i dati della carta?

Risposte guida

1. Sì: mittente sconosciuto, urgenza, richiesta di soldi tramite link.
2. "Non clicchiamo, cancelliamo il messaggio e controlliamo sul sito del corriere."
3. Bloccare subito la carta, cambiare le password, avvisare la banca, la Polizia Postale e il responsabile.

Transazioni online: 5 strumenti di protezione



Crittografia

Rende il messaggio illeggibile senza chiave.



HTTPS

Cifra i dati tra browser e sito.



Certificato digitale

Carta d'identità elettronica del sito.



Firma digitale

Vale come firma autografa.



Accesso

Autenticazione: dimostra chi sei.

Crittografia: simmetrica e asimmetrica

1 Simmetrica

Una sola chiave per cifrare e decifrare.

✓ Veloce
✗ La chiave va consegnata al destinatario: è il punto debole.

Come una cassetta con copia della chiave.

2 Asimmetrica

Due chiavi: pubblica (cifra) e privata (decifra).

✓ Non serve scambiarsi segreti
✗ Più lenta

Come la cassetta delle lettere: tutti imbucano, solo tu apri.

Crittografia simmetrica: come funziona

1

Anna scrive "CIAO" (testo in chiaro).

2

Cifra con la chiave K: ottiene "FLDR" (testo cifrato).

3

Il messaggio viaggia su Internet: per chi lo intercetta è illeggibile.

4

Bruno decifra con la STESSA chiave K e legge "CIAO".

Il problema: come far arrivare la chiave K a Bruno senza che nessuno la copi? Uso tipico: cifratura di file, dischi e backup.

Crittografia asimmetrica: come funziona

1

Bruno crea due chiavi e rende nota la chiave PUBBLICA.

→

2

Anna cifra il messaggio con la chiave pubblica di Bruno.

→

3

Il messaggio viaggia su Internet: nessuno può riaprirlo, nemmeno Anna.

→

4

Bruno decifra con la sua chiave PRIVATA, mai condivisa.

Vantaggio: niente segreti da scambiare in anticipo. In HTTPS le due si usano insieme: l'asimmetrica per scambiare la chiave, la simmetrica per il resto.

Il cifrario di Cesare (chiave = 3)

Chiaro	A	B	C	D	E	F	G	H	I	J	K	L	M
Cifrato	D	E	F	G	H	I	J	K	L	M	N	O	P
Chiaro	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
Cifrato	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

Ogni lettera si sposta di 3 posti in avanti (dopo la Z si ricomincia dalla A).
Esempio: CIAO → FLDR. Per decifrare si sposta indietro di 3.
Giulio Cesare usava un metodo simile per i messaggi militari.

Attività: cifra e decifra

- Cifra il tuo nome con chiave 3 e scambialo con un compagno
- Decifra "FXUD" (chiave 3)
- Decifra "DVVLVWHQCD" (chiave 3)
- Scrivi un messaggio di 2 parole e fallo decifrare
- Perché non è sicuro? Ragiona: quante chiavi possibili ci sono?

Soluzioni

LUCA → OXFD
"FXUD" = CURA
"DVVLVWHQCD" = ASSISTENZA

Solo 25 chiavi possibili: si provano tutte in pochi minuti (attacco a forza bruta). Le chiavi moderne hanno miliardi di combinazioni.

Prima di tutto: come dialogano browser e sito



Tu (browser)

Il "client": chiede una pagina web

Protocollo

Le regole con cui si parlano

Server web

Il computer che custodisce il sito e risponde

Un protocollo è l'insieme di regole con cui due computer si capiscono, come una lingua comune. HTTP è il protocollo del web.

L'indirizzo di un sito (URL)



Il dominio identifica il sito: www.ospedale.it e www.ospedale-it.com sono due siti DIVERSI.
I truffatori creano indirizzi quasi uguali a quelli veri (phishing): controlla sempre come è scritto il dominio.

HTTP: una domanda e una risposta

1

Scrivi un indirizzo o clicchi su un link.

2

Il browser invia una RICHIESTA al server: "dammi questa pagina".

3

Il server invia una RISPOSTA con un codice e la pagina.

4

Il browser mostra la pagina sullo schermo.

HTTP = HyperText Transfer Protocol. Il codice di risposta dice com'è andata: 200 = tutto ok, 404 = pagina non trovata.

Il problema di HTTP: viaggia in chiaro



Tu

Invii utente e password

Chi intercetta

Sulla stessa rete, ad esempio un Wi-Fi pubblico

Sito web

Riceve i dati

```
L'intruso legge:   utente=giulia   password=Ciao1234
```

Come una cartolina: chiunque la maneggi può leggerla.

HTTPS = HTTP + TLS

HTTP

le regole del dialogo

+

TLS

la cifratura dei dati

=

HTTPS

dialogo protetto

C

Riservatezza

Nessuno può leggere i dati mentre viaggiano.

I

Integrità

Nessuno può modificarli senza che ce ne accorgiamo.



Autenticità

Il certificato prova chi è davvero il sito.

Come nasce una connessione sicura (TLS)

1. Il browser saluta: "voglio parlare in modo sicuro".
2. Il sito risponde inviando il suo certificato digitale, con la chiave pubblica.
3. Il browser controlla il certificato e crea una chiave segreta, cifrata con la chiave pubblica.
4. Da ora tutti i dati sono cifrati con la chiave segreta condivisa.

Le due crittografie lavorano insieme: l'asimmetrica per accordarsi in modo sicuro, la simmetrica (più veloce) per il resto della comunicazione.

HTTPS: la comunicazione protetta



Tu (browser)

Invii password e dati della carta

Dati cifrati

In viaggio sono illeggibili per chi li intercetta

Sito web

Ha un certificato digitale che ne prova l'identità

In HTTP i dati viaggiano in chiaro, come una cartolina; in HTTPS sono in una busta chiusa.

HTTP e HTTPS

	HTTP	HTTPS
Dati	In chiaro	Cifrati (SSL/TLS)
Analogia	Cartolina: la legge chiunque	Lettera in busta chiusa
Indirizzo	http://	https:// + lucchetto
Quando	Da evitare per password e pagamenti	Necessario per banca, acquisti, servizi sanitari

Come riconoscere un sito sicuro

- L'indirizzo inizia con https://
- C'è il lucchetto nella barra: cliccalo per vedere il certificato (chi lo ha rilasciato, fino a quando è valido)
- Il dominio è scritto esattamente giusto
- Se il browser avvisa "connessione non privata" o certificato scaduto: NON proseguire

Attenzione

Il lucchetto prova che la connessione è protetta e che il sito è quello che dichiara di essere. Non prova che sia onesto: anche i siti di phishing possono avere HTTPS.



Caso simulato: il Wi-Fi gratuito della stazione

Sara, tirocinante OSS, aspetta il treno e usa il Wi-Fi gratuito della stazione per aprire il Fascicolo Sanitario Elettronico di sua nonna e prenotare una visita.



Domande

1. Che rischio corre se il sito fosse in HTTP?
2. E se fosse in HTTPS?
3. Che cosa dovrebbe fare Sara?

Risposte guida

1. Un intruso sulla rete può leggere password e dati (riservatezza) e modificarli (integrità).
2. I dati sono cifrati: l'intruso vede solo caratteri illeggibili. Meglio evitare comunque operazioni delicate.
3. Usare la rete dati del telefono, controllare https e lucchetto, attivare la verifica in due passaggi.

Attività: ispeziona un sito

- Apri il sito della tua scuola, di una banca e di un'ASL
- Guarda se l'indirizzo inizia con https:// e se c'è il lucchetto
- Clicca il lucchetto: chi ha rilasciato il certificato?
- Fino a quando è valido?
- Discutiamo: perché non si deve pagare su un sito senza https?

Da annotare

Nome del sito · https sì/no · chi ha rilasciato il certificato · data di scadenza.



Certificato e firma digitale



Certificato digitale

Associa un'identità a una chiave pubblica.
Rilasciato da un'Autorità di certificazione.
Garantisce chi è il sito, non che sia onesto.



Firma digitale

Stesso valore legale della firma autografa.
Autenticità, integrità, non ripudio. Firma con la chiave privata, verifica con la pubblica.

Esempio: un referto firmato digitalmente non può essere modificato senza che si veda.

Meccanismi di autenticazione



Conoscenza

Qualcosa che sai: password, PIN.



Possesso

Qualcosa che hai: tessera, chiavetta, smartphone con app.



Caratteristiche fisiche

Qualcosa che sei: impronta, volto, iride.

La scelta migliore: usarne più insieme (bancomat = carta + PIN; SPID = password + codice).

Il decalogo dell'operatore digitale

- Password lunghe, segrete e diverse
- Blocca lo schermo quando ti allontani
- Non condividere il tuo account
- Non cliccare link e allegati sospetti
- Aggiorna e fai i backup
- Niente dati di assistiti su WhatsApp o foto personali
- Controlla https:// e il lucchetto
- Se sbagli, dillo subito al responsabile

Perché conta

Fiducia e segreto professionale dipendono anche da come proteggi le informazioni che le persone ti affidano.



Verifica: riservatezza, integrità o disponibilità?

- Un estraneo legge una cartella clinica
- Un virus cambia la data di nascita di un utente
- Il server si spegne per un black out
- Una mail con l'elenco utenti va alla persona sbagliata
- Un ransomware blocca tutti i PC della RSA

Soluzioni

1 Riservatezza
2 Integrità
3 Disponibilità
4 Riservatezza
5 Disponibilità (e forse riservatezza)



Sei un sistema sicuro?



Solo per chi deve vedere i dati.
Giusti.
Pronti quando servono.

Riservatezza · Integrità · Disponibilità